

Kevin Kallish

Prof. Whittaker

GSC 560

11/17/24

Cybersecurity in the Public and Private Spheres: Analyzing Roles, Challenges, and Paths Forward

The world of cybersecurity is distinctive, standing out as one of the few industries where public and private companies face threats from common sources. The same groups that frequently target the U.S. government for intelligence are also attacking private businesses, seeking trade secrets, financial gain, or simply to undermine the confidentiality, integrity, and availability of information.

Although the public and private sectors each bring unique strengths and weaknesses to cybersecurity, neither is inherently more capable than the other. They occupy different roles, yet these roles are interdependent. I believe it's essential that they begin working together as a cohesive unit within the U.S. cybersecurity landscape. Given the growing cyber threats posed by countries like China, Russia, North Korea, and Iran, which have been responsible for numerous attacks on both U.S. companies and government systems, it's imperative that we adapt. These nations not only engage in cyber-espionage themselves but also provide safe harbor to Advanced Persistent Threat (APT) groups targeting the United States.

In this essay, I will examine the strengths and weaknesses of public and private sector approaches to cybersecurity, making the case for a unified, integrated cybersecurity strategy within the United States to confront and counter these growing threats more effectively.

Both the public and private sectors contribute essential strengths to cybersecurity. Public initiatives focus on protecting sensitive information within government agencies and critical infrastructure, prioritizing national security and threat intelligence to defend against advanced persistent threats (APTs).

The Cybersecurity and Infrastructure Security Agency (CISA) plays a key role in these efforts by monitoring, analyzing, and sharing information on cyber threats, attacks, and vulnerabilities. CISA conducts risk and vulnerability assessments to identify significant risks faced by state governments and other agencies. CISA enhances the public sector's overall defense capabilities by providing technical reports with actionable recommendations (Cybersecurity and Infrastructure Security Agency).

Another major player, the U.S. Department of Homeland Security (DHS), publishes reports on cybersecurity challenges and strategies, particularly those impacting critical infrastructure (Department of Homeland Security). Additionally, the National Institute of Standards and Technology (NIST) developed the widely respected NIST Cybersecurity Framework, which sets best practices and establishes a shared language that cybersecurity professionals can use to address security challenges (National Institute of Standards and Technology). Together, these agencies ensure public and private sectors are informed of emerging threats.

Public-sector agencies, including other “three-letter” intelligence agencies, share detailed threat intelligence that private companies can use to guide their cybersecurity strategies and bolster their defenses. The public sector enforces cybersecurity laws and regulations that uphold data

security and privacy standards for the private sector. Key regulatory measures include the Federal Information Security Management Act (FISMA), which requires federal agencies to identify, assess, and mitigate cybersecurity risks (Centers for Medicare and Medicaid Services), the Computer Fraud and Abuse Act (CFAA), which prohibits unauthorized access to computers and cybercrime (U.S. Department of Justice), and the Homeland Security Act of 2002, which created DHS and established it as a watchdog for emerging threats (U.S. Department of Homeland Security). Public sector strengths support a safer digital landscape for both public and private organizations.

The private sector's strengths lies in its agility and rapid innovation, allowing it to stay on the cutting edge of emerging threats. Companies such as Illumio, Aqua Security, Cribl, and Buoyant lead innovation within the cyber community focusing on groundbreaking developments to meet private-sector needs.

Notable innovations from these companies include zero-trust micro-segmentation, which blocks lateral threat movement within networks, and automated detection systems for containerized environments. Advanced SIEM platforms that leverage analytics and AI for threat detection and neutralization are also thriving due to private sector investment. Huge amounts of funding for research and development drives innovation in the private sector.

Private companies are also close to the end users, giving them unique insights into user behavior, habits, and network patterns. This proximity enables tailored security measures that facilitate easier threat detection and seamless integration of security features into business operations. This allows businesses to focus on doing business while maintaining robust security.

Perhaps the private sector's greatest strength is its financial incentive to protect data. Every non-governmental company is directly incentivized to keep customer data secure, as people avoid businesses they perceive as unsafe. The 2011 hack of Epsilon, which is a data and technology service provider. This attack leaked data from 75 major companies who do business with Epsilon. Best Buy, JP Morgan Chase, and Targets data was all breached in this attack resulting in \$4 billion in damages and lost customer trust. (Proofpoint). Private companies must invest heavily in cybersecurity in order to keep this from happening to them.

Public sector cybersecurity has significant barriers to progress. Due to the sheer size of government and the legal processes required to implement changes, advancements are often slow. Cybersecurity can sometimes take a backseat to other pressing domestic and foreign policy issues, and even when cybersecurity measures are included in legislation, they're often attached as riders on larger bills, which can get stalled in Congress during debates over other issues. Decision-making within government agencies tends to be slow due to extensive oversight requirements, resulting in a long, costly review process. Once the policy is approved, procurement rules require agencies to acquire technology in ways that prioritize cost-effectiveness and secure manufacturing, which often leaves them with outdated technology and policies. Public organizations must also meet strict compliance standards set by the U.S. government.

Funding is a critical hurdle, public sector cybersecurity budgets depend on the federal budget cycle which is a cycle frequently caught up in political debates in Washington. This dependence on the government's budget cycle can lead to delays, shutdowns, and, in some cases, furloughed employees. Hiring is similarly tricky, with government agencies facing long hiring processes and limited budgets, making it hard to compete with private companies. This funding gap is perhaps

the most serious issue for public sector cybersecurity: on average, cybersecurity analysts earn 20–30% more in the private sector, making it difficult for the government to attract and retain top talent (Miller, Aaron, et al).

The private sector faces its own cybersecurity challenges, particularly due to fragmentation within the industry. Every company in the United States has individual needs for security. This leads to inconsistent approaches to cybersecurity. While laws require companies to meet basic cybersecurity standards, many prioritize profit over security, cutting costs where possible. This often results in poor network security, increasing the risk of attacks that ultimately cost more in the long run. While the focus on profitability is understandable from a business perspective, upper management and investors' limited resources and budget constraints often make cybersecurity a “necessary” but underfunded department that doesn’t generate direct profits, leading to corner-cutting.

Another significant weakness in private sector cybersecurity is the limited access to threat intelligence. While companies can use open-source intelligence, it’s not nearly as comprehensive as the information gathered by the CIA, FBI, NSA, CISA. This gap between government intelligence and private companies puts businesses in a reactive position, forcing them to respond to threats rather than proactively defend against emerging threats that government agencies may already be aware of.

For private cybersecurity to become more effective, increased investment, universal adoption of zero-trust policies, and enhanced awareness for employees and security teams about emerging threats are needed. This could be achieved by expanding the authority of an existing agency like CISA or creating a new agency dedicated to addressing private-sector vulnerabilities. While

CISA collaborates with government agencies and safeguards critical infrastructure, it doesn't fully address the gaps in private-sector cybersecurity, leaving the nation exposed.

A federally backed oversight board could establish universal security standards tailored to the specific data and risks businesses face. For example, a small business like Crumbl Cookies, which primarily handles customer payment data, would fall under a lower security tier, requiring basic compliance measures, a defense contractor like Lockheed Martin, which manages highly sensitive information, would need to adhere to the highest standards, including robust physical and cybersecurity protocols.

This agency would also enforce accountability. Companies failing to meet these standards would face serious consequences, with C-suite executives and board members liable for negligence.

Drawing inspiration from the Payment Card Industry Data Security Standards (PCI DSS), this model would extend beyond voluntary compliance and lawsuits, embedding personal accountability to ensure cybersecurity becomes a top organizational priority rather than a begrudging expense.

additionally, this agency would bridge the gap between the public and private sectors.

Intelligence gathered on cyber threats would be shared with federal agencies and private companies. These organizations would only get intelligence that is relevant to what industry they are in. This fosters a shared knowledge of defense against threats. It would advocate for greater cybersecurity investment within the public sector and education for policymakers about its critical importance. This would help investment in public sector cybersecurity and in turn, make it able to compete with private companies, particularly in offering salaries that attract top talent.

Overall, cybersecurity must evolve into a more cohesive and unified force. We need an agency that effectively bridges the gap between the public and private sectors to achieve this. An agency like this would allow for collaboration across cybersecurity departments in America, ensuring that both sectors work together to reduce the frequency of cyber breaches and strengthen the nation's cyber infrastructure. While perfection may never be attainable for either sector, I firmly believe that creating a centralized agency to unify cyber efforts would profoundly positively impact the cybersecurity industry.

Sources

- Cybersecurity and Infrastructure Security Agency. *Federal Government*. Cybersecurity and Infrastructure Security Agency, www.cisa.gov/audiences/federal-government. Accessed 15 Nov. 2024.
- National Institute of Standards and Technology. *History*. National Institute of Standards and Technology, www.nist.gov/history. Accessed 15 Nov. 2024.
- Anchore. *Cybersecurity Compliance: Laws & Regulations to Know*. Anchore, www.anchore.com/compliance/. Accessed 15 Nov. 2024.
- Cyber Defense Magazine. "Cybersecurity Jobs in the Private vs. Public Sector." *Cyber Defense Magazine*, www.cyberdefensemagazine.com/cybersecurity-jobs-in-the-private-vs-public-sector/. Accessed 15 Nov. 2024.
- Department of Homeland Security. *Cybersecurity*. U.S. Department of Homeland Security, www.dhs.gov/topics/cybersecurity. Accessed 15 Nov. 2024.
- U.S. Department of Justice. *JM 9-48000: Computer Fraud*. U.S. Department of Justice, www.justice.gov/jm/jm-9-48000-computer-fraud. Accessed 15 Nov. 2024.
- U.S. Department of Homeland Security. *Homeland Security Act of 2002*. U.S. Department of Homeland Security, www.dhs.gov/homeland-security-act-2002. Accessed 15 Nov. 2024.
- Illumio. *What We Do*. Illumio, www.illumio.com/company/what-we-do. Accessed 15 Nov. 2024.
- Aqua Security. *About Us*. Aqua Security, www.aquasec.com/about-us/. Accessed 15 Nov. 2024.
- Cribl. *Products*. Cribl, www.cribl.io/products/. Accessed 15 Nov. 2024.

- Buoyant. *Linkerd Enterprise*. Buoyant, buoyant.io/linkerd-enterprise. Accessed 15 Nov. 2024.
- Proofpoint. "Throwback Hack: The Epsilon Email Breach of 2011." *Proofpoint*, www.proofpoint.com/us/blog/insider-threat-management/throwback-hack-epsilon-email-breach-2011. Accessed 15 Nov. 2024.
- Miller, Aaron, et al. *The Future of Cybersecurity and Artificial Intelligence: Opportunities and Challenges*. RAND Corporation, www.rand.org/pubs/research_reports/RRA660-7.html. Accessed 15 Nov. 2024.